

Authentication Monitoring and Small-Business Web App Security Hardening

Scenario

EastBridge Learning Portal is a fictional small education-services company running a PHP/MySQL web application on cPanel/VPS-style hosting. The environment includes a public website, client portal, admin portal, and backend APIs maintained by a lean development team without a dedicated cybersecurity function.

Objective

Improve authentication visibility, session accountability, and deployment hygiene for a small-business web application where operational security controls had not matured at the same pace as the product.

Security Problems Identified

The application had limited centralized tracking for failed logins, successful logins, password reset requests, password setup events, revoked sessions, and suspicious access patterns. Session records also needed better context such as IP address, approximate region, account type, user agent, and device hints. Normal API traffic could create excessive raw log growth, while public web-root storage practices created risk of accidental exposure of backups, logs, source archives, and configuration-like files.

Controls Implemented

The hardening plan introduced authentication audit logging, login attempt tracking, password reset and setup tracking, session metadata capture, bounded session activity summaries, and detailed event logging for risky requests such as failed authentication, blocked access, revoked sessions, HTTP 401/403/429/5xx responses, impersonation, and suspicious activity.

Evidence: Example Auth Event Matrix

Event	Account Type	Result	Region	Device	Reason
Login attempt	Admin	Failed	Nairobi	Desktop	Invalid password
Login attempt	Staff	Success	Nairobi	Desktop	Valid credentials
Password reset	Client	Requested	Unknown	Mobile	Reset link sent
Session request	Admin	Blocked	Different country	Desktop	Reauthentication required

Example Session Summary

```
{"session_id_hash":"demo_session_hash","account_type":"staff","request_count":184,"error_count":3,"last_path":"/api/member/profile","last_status_code":200,"path_counts":{"dashboard":12,"api/member/profile":8,"api/payments/list":5}}
```

Analysis

The controls improve detection, accountability, and incident investigation by preserving the events most useful for security response while summarizing normal activity to control storage growth. This is especially useful for small teams that need practical visibility without a full security operations center.

Recommendations

Move backups, SQL dumps, logs, dot-directories, source archives, and token/config-like files outside public web roots. Add deny rules for sensitive extensions, rotate potentially exposed credentials, add MFA for admin/staff accounts, retain detailed risky-event logs, and consider lightweight monitoring such as Wazuh for VPS/cPanel environments.

Reflection

This project connects software engineering work with cybersecurity principles: logging, detection, session security, least privilege, deployment hygiene, incident response, and risk-based remediation.

Portfolio Status

Completed